Repository review report

ledgerline-api: two high-priority defects in payment safety, both with clear fixes

Prepared for [Customer name]. Seven findings from four reviews of the default branch, each tied to the file and line it came from.

Repository `acme/ledgerline-api`	Commit reviewed `a41c9e2 (main)`	Report date 19 October 2026
Language Python 3.12 · FastAPI	Reviews run Code, security, test, documentation	Report ID `CF-RPT-0142`

01 Summary

LONGTOKEN_LONGTOKEN_LONGTOKEN_LONGTOKEN_LONGTOKEN_LONGTOKEN_LONGTOKEN_LONGTOKEN_LONGTOKEN_LONGTOKEN_L VARIABLE_CONTENT_END Two defects need attention before the next release: idempotency keys expire before clients stop retrying, which allows a duplicate charge, and webhook signatures are checked in a way that can be bypassed when a secret is missing. Both are small, contained changes. The remaining five findings are maintenance items.

7	2	3	2
Findings in total	P1 · fix before release	P2 · fix this cycle	P3 · when convenient

02 Scorecard

Categories are scored only where a review examined them. Unexamined categories are marked rather than estimated.

CATEGORY	SCORE	BASIS
Correctness	17 / 25	One P1 (F1). Ledger posting and balance math read in full.
Security	15 / 25	One P1 (F2), one P2 (F4), one P3 (F6). 14 files read.
Test quality	14 / 25	Line coverage 71%. No tests reach the refund path (F5).
Documentation	20 / 25	Accurate API reference; setup guide out of date (F7).
Architecture	19 / 25	Clear module boundaries; one shared-state concern in F1.
Performance	Not scored	Not examined in this engagement.
Dependencies	Not scored	Dependency review not run.
Scored categories	**85 / 125**	Five of seven categories
VARIABLE_ROW_000	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_001	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_002	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_003	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_004	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_005	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_006	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_007	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_008	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_009	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_010	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_011	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_012	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_013	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_014	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_015	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_016	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_017	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_018	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_019	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_020	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_021	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_022	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_023	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_024	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_025	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_026	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_027	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_028	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_029	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_030	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_031	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_032	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_033	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_034	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_035	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_036	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_037	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_038	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_039	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_040	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_041	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_042	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_043	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_044	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_045	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_046	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_047	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_048	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_049	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_050	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_051	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_052	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_053	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_054	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_055	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_056	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_057	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_058	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_059	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_060	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_061	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_062	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_063	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_064	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_065	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_066	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_067	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_068	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_069	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_070	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_071	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_072	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_073	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_074	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_075	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_076	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_077	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_078	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_079	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_080	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_081	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_082	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_083	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_084	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_085	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_086	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_087	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_088	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_089	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_090	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_091	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_092	Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_093	Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_094	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_095	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_096	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_097	Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content Synthetic evidence content	
VARIABLE_ROW_098	Synthetic evidence content	

CATEGORY	SCORE	BASIS
VARIABLE_ROW_099	Synthetic evidence content Synthetic evidence content	

03 All findings

ID	PRIORITY	FINDING	LOCATION
F1	P1	Idempotency keys expire before retries end	`middleware/idempotency.py:41`
F2	P1	Webhook signature check can be bypassed	`webhooks/verify.py:18–27`
F3	P2	Sort column interpolated into SQL	`ledger/queries.py:88`
F4	P2	API keys written to debug logs	`middleware/auth.py:33`
F5	P2	Refund path has no tests	`refunds/service.py`
F6	P3	Stack traces returned when ENV is unset	`app.py:57`
F7	P3	Setup guide names a removed command	`README.md:44`

04 Priority findings

P1 · High F1 · Correctness

Idempotency keys expire before clients stop retrying

Keys are kept for 24 hours, but the retry policy allows clients to resend a payment for up to 72 hours. A retry after the key expires is treated as a new payment and charged again.

```
ledgerline/middleware/idempotency.py:41
    IDEMPOTENCY_TTL = 60 * 60 * 24        # 24 h

ledgerline/config/retry.py:12
    MAX_RETRY_WINDOW_HOURS = 72
```

Recommended change

Derive the key lifetime from the retry window, with a margin, so the two cannot drift apart.

How to verify

Test T-01 in the test plan replays a payment at 48 hours, after the key expires and inside the retry window, and expects the original response.

P1 · High F2 · Security

Webhook signatures can be forged when the secret is unset

If the environment variable is missing, verification falls back to a fixed development secret, and the comparison is not constant-time. Anyone who knows the default can post a payment-status webhook that the service accepts.

```
ledgerline/webhooks/verify.py:18
    secret = os.getenv("WEBHOOK_SECRET", "dev-secret")
ledgerline/webhooks/verify.py:27
    if signature == expected:
```

Recommended change

Refuse to start without the secret, and compare with `hmac.compare_digest`.

How to verify

Tests T-03 and T-04 cover startup without a secret and a forged signature.

05 Scope and limits

Examined

All 62 source files under `ledgerline/`, the test suite, CI configuration and README. Findings are from reading source; behavior was not executed unless a finding says so.

Not examined

Infrastructure code, production configuration, third-party dependencies and runtime performance. Absence of findings in these areas is not evidence of their quality.

06 Next steps

1. Fix F1 and F2 before the next release. Each touches one file.
2. Accept or reject the proposed issue set (seven issues, one per finding).
3. Run the review-driven test plan to confirm both fixes and close the refund coverage gap.
4. Decide ADR-0007 on moving idempotency state out of the cache.

CodeFriend is a product of Agent Logic, Inc. · © 2026 · **Confidential — prepared for [Customer name]**